General Informations

The ones marked in green in the title of the first exam questions are thought to be the answer to the question. The dark orange ones are the ones that are thought to be correct with the 2nd possibility in unsure questions. Please ignore the yellow options. Questions starting and ending with a dot (...) appeared in 2 separate exams and were marked in this way.

In the exam under the title of second exam questions, there were a total of 82 questions in the exam, 7 of which were over vm, so there were 75 questions in total, except for the questions below, there are photos.

The questions in the title Extra test exam questions are some of the questions in the test exam. There are photos that are not written.

First Exam Questions

question 2

Which of the following vectors is most effective in launching attacks aqainst air-gapped

- Physical access
- Industrial protocol manipulation
- web interface manipulation
- Database access

question 3

Which of the following is used to integrate and extend functions such as data communication and alarm dispatching?

- Remote terminal unit (RTU)
- SCADA manager
- Front-end processor (FEP)
- Master terminal unit (MTU)

question 4

Which database would an attacker access to update a process set point and close a valve?

- Analytic database
- User interface database
- Runtime database
- Asset database

question 5

what device could most likely be attacked over the intetnet to eventually enable an attacker to Jump an air-gapped network in order to attack protcted ICS systems?

- PLC

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

- Historian
- HMI
- FEP
- Field Engineer's laptop

question 6…

A keyed lock on a facility's backdoor is an example of which type of control?

- Delaying
- Corrective
- Avoidant
- responsive

question 7

Which of the followinq is the most common confiquration vulnerabilty for Purdue Model level 2 and 3 systems?

- Unpactcehd operating systes
- Email gateways with weak filters
- Physically accessible sensors
- Open DMZ firewall ports

…question 8 ….

What needs to be considered when Planning a VSAT communications deployment to a remote site?

- Inability to leverage frequency hopping
- Inability to leverage QOS
- Latencies greater than 1000 ms
- Disruption tol ine-of-sight

question 9..

Which of the following is an example of a deterrent control?

- Alarm thresholds for failed Access attemtps
- Nighttime ligtting around the perimeter of a facility
- Hidden cameras monitoring Access to restricted areas
- Smart card readers for after hours building entry

question 10

An analyst is making a list of vulnerabilities. Which sitiation should be identified as a vulnerability

- A hacktivist group has developed an exploit for a common SIS controller
- A server is accessed by remote technicians using SSHv1
- A competitor has identidfied a way to exfiltrate inetllectual property

Hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

- A hostile nation state is targetting the organization

question 11

Within a Bussiness Continuity Plan, which of the following defines Recovery Point Objective?

- How much data you can afford to lose considering the state of available backups
- A goalof an actionable plan to restore an organization to normal operating conditions
- The length of time a sstem can be unavailable during the restoration process
- An anticipated date and time when full restoration of a system will be achieved

question 12

Which of the following would be part of the Wireshark display filter to determine whether a device poising as a modbus/tcp client is writing to a field device's registers?

Func_code

Analysis.flags

WriteMAsk

Ctl.dfc

question 13

An ICS network design requires the ability to transmit data from historians on the operations network to read-only database on the business network. The data is used for analysis and accounting. Which of the following security controls should be used to implement this network communication requirement securely?

- Unidirectional Gateway
- Transport Layer Security
- Virtual Private Network
- Network Access Control

question 14...

An attacker crafts an email that will send a user to the following site if they click a link in the message. What else is necessary for type of attack to work?
hmi.giac.org/diaconnectsensor012

- the user must be authenticated to the hmı interface before clicking the link
- The user clicking the link must be an administrator on the network
- The attacker must obtain a session cookie from an authorized HMI user
- The attacker must enclose the url parameter with <script> tags to run the code

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

question 15

Where do they system binaries in a typical Unix installation reside?

- /var
- /home
- /dev
- /usr

question 16 – no question

no question

Are the operational needs of the ICS more critical than the ris of the unpatched vulnerability?

Is there a viable workaround for the vulnerability until the ICS can be safely taken offline for patching?

Was the patch developed by an os vendor or the ICS vendor of the affected application?

Is there an active IoC available for identifying attempted exploitiation of the vulerabilitiy

hide01.ir

question 17

which of the following is needed for policies to be effective in an organization

- mission statement
- comply with NERC regulations
- culture of compliance
- versiponing information

question 18

An attacker goes to www.mycoolsite.com and is asked for a password, so they try www.mycoolsite.com/cool, www.mycoolsite.com/cooler, and www.mycoolsite.com/cooles each time they are asked for a password. Finally the attacker tries www.mycoolsite.com/secret and obtains access to www.mycoolsite.com which kind of exploit is this?

- Cross-site request forgery
- Authentication bypass
- Password brute-force
- Sql injection

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

question 19

Which characteristic indicates the presence of an unencoded RSA key when using an entropy graphing tool on an EEPROM memory sample?

A flat section of blocks within the data

An elliptical curve in the data

A spike in the randomness of the data

A series of peaks and valleys

question 20

When deploying ICS hardware, which of the following is a security concern with regard to cryptography?

- Unsalted Hashes
- Preloaded keys
- Asymmetric algorithms
- Reused nonces

question 21…

which of the following is the immediate result of a buffer overflow attack?

- Database credential harvesting
- Code execution
- Privilege escalation
- Exfiltration of sensitive information

question 22

Which of the following does NERC EOP-008-1 require of a backup control center?

- Must be tested at least quarterly from the pitmary facility
- Must be a duplicate of the primary facility's network
- Must be running at all times parallel with the primary facility
- Must be completely independent of the primary facility

question 23

Which of the following is a security benefit of virtualizing hardware in an ICS environment

- Decreases the amount of troubleshooting needed to resolve alarms
- Centralizes systems management of servers across network zones
- Facilitates creation of a test environment for patching
- Reduces rack space needed by reducing number of physical servers

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

question 24

Which of the following defensive actions could increase risk if implemented in DCS architecture

- Isolating the active directory domain in purdue level 3 from the enterprise active director domain
- Blocking outbound internet access from anti-virus deployment servers located in the supervisory control layer
- Deploying an intrusion prevention system inline between the supervisory control layer and the process control layer
- Implementing a VPN over a SCADA WAN link for communications between Purdue level 3 systems and remote sites with purdue levels 0, 1, 2

question 25

How could wireshark be utilized in an attack against devices at purdue levels 0 or 1

- Capture serial and fieldbus communications sent by networked devices
- Detect asymmetrical keys by identifying randomness in a data dump
- Detect open ports on a device by sending packets and analyzing the responses
- Brute force crypto keys in an encrypted pcap file
- Capture communications between chips on a board

question 26

in a Unix system v-style initialization, what occurs at runlevel 6?

- The display manager starts
- The system shuts down
- Administrative tasks
- A system reboot

question 27

Which of the following is part of the Respond function of the NIST CSF (cybersecurity framework)?

- Restoring from backup a system that had been compromised
- Performing forensics analysis on a system and eradicating malware
- Discovering malicious activity on the network using multiple sensors
- Limiting user access to only those network resources necessary for them to do their jobs

question 28

what would the following command be used to accomplish?

openssl dgat sha256 -hmac “this key”secretmessage.key

- Create an asymmetric key pair on a server with a passphrase protected private key
- Create an asymmetric key pair on a server and encrypting the secret message
- Prevent a secret message from being altered by an attacker while in transit
- Prevent a secret message from being read during a man in the middle attack

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

question 29

Which term refers to the amount of data loss that is acceptable when bringing critical system back online after an unexpected outage?

- Recovery point Objective
- Maximum Tolerable Downtime
- Single loss Expectancy
- Business impact Analysis

question 30…

What is a benefit of log aggregation?

- Eliminates the need for baselining normal log activity
- Assists in analysis of log data from multiple sources
- Reduces system load on logging devices
- Simplifies initial setup of logging in the environment

question 31

which of the following indicates a failure in the lessons learned and preparation pahases of an organization's incident response program?

- Two undocumented applications were unable to be brought up after shifting operations to a temporary warm site
- A recently deployed website fell victim to a spam attack using the same vector as an earlier attack on an existing website
- A recently deployed system colud not be recovered following a crash due to a lack of backups
- Two high level managers fell victim to spear phishing attack before new spam signatures were available to block the emails

question 32…

Which command can be used on linux system to search a file for a string of data and return the results to the screen?

- Type
- Grep
- Tail
- cat

question 33

question 34

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

Which calculation determines whether implementing a new security countermeasure reduces enough risk to make it a worthwhile business decision?

- Recovery point objective
- Single-loss expectancy
- Risk analysis
- Cost-benefit analysis

question 35

An engineer has analyzed the subsystem of a power plant and identified physical and logical inputs that could expose the subsystem to unauthorized access. What has the engineer

- A vulnerability scan
- A risk analysis
- An attack surface
- A threat model

question 36

During testing of a new web application, the QA analyst notices that database exception mis thrown when a single quote character is entered as part of the username in the login box, but no error occurs when it is entered as part of the password. Based on this information only, what is the correct explanation for this behavior?

- Sql injection may be possible, allowing an attacker to access valid usernames and password information
- Cross-site request forgery may be possible, allowing attacker to access valid usernames and password information
- Sql injection may be possible, allowing an attacker to access valid usernames, but password are protected
- Cross-site scripting attacks may be possible, allowing attacker to bypass the login and impersonate users

hide01.ir

question 37...

Which of the following can an attacker gain by obtaining plc logic project files for a scada system

- Schedule of vendor product releases
- Data regarding personal and hiring practices
- Details about the network architecture
- Information about operational rulesets

question 38

What is recommended purdue level for compute-based solid state devices that control industrial equipment and processes?

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

- 1
- 3
- 0
- 4

question 39

In an ICS network, which database type is typically used in configuring ICS devices?

- Process collection
- Runtime
- Application support
- project

question 40

Which of the following is a feature of an HMI in an ICS environment?

- Can be used for distributing application modifications
- Contains the logic to automatically control a process
- Can be used to manually control a process
- Contains log and tag values that can be used for troubleshooting

question 41

NERC EOP-008-1 requires that entities have a plan to address the loss of control center functionality including the requirement of equipping a fully functional and secured backup site. Within this standard, how long does the entity have to perform the transition period of personal and systems during an emergency situation?

- 1 hour
- 24 hour
- 8 hour
- 2 hour

question 42

What is use of network address translation

- To make access list configuration easier
- To maximize firewall functionality
- To hide private network addresses
- To enable network routing functionality

question 43

which of the following types of network uses a cellular provider’s network for wan communications?

- GSM
- WirelessHART
- BGAN

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

- ZigBee

question 44

The head of the IT department sent a directive stating that all company communication must use TLS in order to prevent unauthorized disclosure of information, Which part of the C-I-A model is the head of IT concerned with

- Identity
- Confidentiality
- Availability
- Integrity

question 45

Which of the following provides the most significant risk reduction for remote connections to the ICS network?

- Turning off wireless SSID broadcast
- Tying the domain to an unidentified IP address
- Using an unrelated domain name
- Multi-factor authentication

question 46

Which of the following is designed for analyzing the electrical waves of an electricity grid with highly accurate timestamps

- Digital protective relay
- Inelligent end device
- Phasor measurement unit
- Human machine interface

question 47

what filter could a security analyst use in the wirehark GUI to display HTTP (port 80) packets going to host 192.168.10.14?

- http && ip.addr == 192.168.10.14
- port 80 && addr == 192.168.10.14
- tcp and port 80 and host 192.168.10.14
- -p 80 192.168.10.14

question 48

Which of the following protcols is used for serial communications?

- RS-232
- DCOM
- UDP

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

- DNP-3.0

question 49…

For application-aware firewalls filtering traffic between trust zones, which of the following policies should be applied to a packet that doesn't match an existing rule?

- Application allow list
- Default deny
- Default alert
- Application deny list

…question 50…..

which of the following is an example of quantitative risk assessment

- An audit of sensitive network segments identifies fifty high priority vulnerabilities
- Reporting the recovery from a database crash will cost the organization one million dollars
- Identifying the attacking host to develop custom IDS signatures
- Assigning an individual to monitor the WİFİ access log data

…question 51…

which type of process is described below?

The station a stamping machine receives 250 kg of rolled stock drom roller station B, Which it satmos into bearings

- Distributed
- Continuous
- Batch
- discrete

question 52

Which of the following is a software-based method for creating multiple network segment on a single switch

- Arp
- Acl
- Vlan
- Vpn

question 53

question 54…

An attacker writes a program that enters a large number of characters into the password field of a website, followed by a command. The website gave him administrative access, even though he did not use a valid username or password

What is the name of this attack?

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

- Buffer overflow
- Man-in-the-middle
- Cross-site-scripting
- Fuzzing

question 55

An active Directory administrator edits the Macimum Password Age GPO computer settings for the 'SiteEngineers' organizational unit (OU), Which of the following is required for the GPO to be enforced

- The computer's local password policy for Maximum Passowrd Age must be less restrictive than the OU policy
- A domain user must log onto a computer in the SiteEnginers OU
- The computer must be powered on an joined to the SiteEngineers OU
- The computer's local password policy for Maximum Password Age must be unconfigured

question 56 .....

An administrator relaxes the password policy during disaster recovery operations. What is the result of this action?

- Positive effect on recovery time objective (RTO)
- Increased risk
- Reduced insurance needs
- Negative effect on recovery point objective

hide01.ir

question 57...

Which of the following types of network devices sends traffic only to the intended recipient node ?

- Wireless access point
- Ethernet switch
- Wireless bridge
- Ethernet hub

question 58

Which of the following should be enabled on a windows domain to monitor when new users are added to a privileged group like Domain Administrators?

- Audit Policy Change
- Audit Account Management
- Audit Directory Service Access
- Audit Privilege Use

question 59

When using the ISA-99/IEC-62443 architecture standard to prioritize risk, what trust level is appropriate for an engineering workstation with direct access to facility's Emergency Shutdown Systems?

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

- Level 5
- Level 4
- Level 0
- Level 2

question 60

Which type of process is described below?

A fermentor's glycol jacket must maintain a steady temperature during and between batches of bear.

- Discrete
- Continuous
- Batch
- Manual

question 61

A remote site with the following design criteria needs to implement a wireless technology what technology should be used

- The terminal will run on solar powered battery and must use less than 25 watts at idle and 50 watts during transmission
- The receiver will be mobile
- Minimum download and uplink speed of 300 kbps
- Man in the middle attack not possible with the use of malicious base transceiver stations (BTS)

- BGAN
- VSAT
- Satellite dish
- GSM

hide01.ir

question 62

To maintain reliable operations for the Bulk Electric Systems (BES), the NERC EOP-008-1 standard requires which of the following?

- Full review and exercise of the backup plan every other year
- A review and updating every two years of both the primary and backup site documentation
- The ability of the backup site data to be consistent with the primary site within two hours of theprimary's failure
- A transition period of less than two hours between the loss of primary control center functionality and the time to fully implement backup functionality

question 63 no question…

- RDP does not work outside of a local network

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

- The setting was automatically overwritten by a GPO
- Gpedit.msc must be used for the change to be persistent
- The engineer needs to be added to the “Remote Desktop Users” group

question 64…

Which of the following scenarios indicates a normal flow of the Modbus TCP protocol

- RTU device initiates connection to FEP over tcp/502
- HMI device initiates connection to PLC over tcp/502
- Server station(s) and field devices initiate communication bidirectionally over
- Field devices poll the network over tcp/502 to seek the server station

question 65

Which of the following is typically performed during the recovery phase of incident response?

- Updating the organization’s security policies to prevent future breaches
- Patching and configuring systems to meet established secure configuration standards
- Finding the root cause or vector used by the attacker to gain entry and maintain access.
- Making a forensic image of the system(s) involved in the incident

question 66

According to the DHS Suggested patch decision tree, what should the next step be if there is a vulnerability with an available patch, but without an available workaround?

- Determine if the vulnerability affects the ICS
- Identify the vulnerability and the available patch
- Test and apply the patch
- Determine if the operational needs are greater than the risk

question 67

A business has established an organization-wide policy to manage cybersecurity risk, …… conducts annual risk reviews to help to guide their cybersecurity strategy, process, ……. Incident response procedures. In which implementation tier of the NIST Cybersecurity Framework are they?

- Adaptive
- Risk informed
- Repeatable
- Partial

question 68

question 69…

which control prevents threars to Integrity

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

- Implementing digital signatures
- Logging IDS alerts
- Firewall egress filtering
- Centralized LDAP authentication

question 70

question 71…

Analyze the Wireshark output below. What step should the system administrator take to prevent a future attacker from being able to obtain account credentials and log into the System?

192.168.1.3	FTP	96	Response:	220 Website FTP Server Ready
216.251.43.98	TCP	66	62598-21	[ACK] Seq=1 Ack=31 Win=131736
216.251.43.98	FTP	88	Request:	User ftp.vestfam.com
192.168.1.3	TCP	66	21-62598	[ACK] Seq=31 Ack=23 Win=4402
192.168.1.3	FTP	109	Response:	331 Password required for ftp
216.251.43.98	TCP	66	62598-21	[ACK] Seq=32 Ack=74 Win=131688
216.251.43.98	FTP	81	Request:	PASS password

- Use a protocol like SSH or SSL/TLS
- Use a pass phrase instead of a password
- Apply input validation to prevent SQL injection
- Enable lockouts for this application account

hide01.ir

question 72

Which of the following is an attack vector for physically connecting to an embedded RS-232

- Telnet
- RS-232
- VxWorks
- SFTP

question 73…

Which of the following describes a stratum its associated value for a network time … server?

- The amount of acceptable delay in synching hosts
- The allowable millisecond drift between a server and client
- The protocol used to sync devices
- The proximity to a reference time server

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

question 74...

Which tool can be used to generate randomized passwords for local Administrator Account

- PAWS
- LAPS
- LDAP
- EMET

question 75...

Understanding current threats and their risk to organizational operations is part of which NIST CSF(cybersecurity framework) function?

- Identify
- Detect
- Respond
- Protect

question 76

What is characteristic of Windows Server Update Services (WSUS) in an ICS environment?

- Requires the clients to connect to the internet to download patches
- Inventions both hardware and software within an Active Directory domain
- Permits the administrator to create third party software patches
- Allows the administrator to create custom groups of computers

question 78

An industrial network is segmented by firewalls into three zones. Which of the following devicesis most likely to be in the same zone as the HMI workstation?

- Data historian
- Programmable logic controller
- Remote terminal unit
- Variable speed drive

...question 79.....

Which of the following personel is typically responsible for designing and optimizing systems used in the ICS environment?

- Field Technician
- Programmer
- Operator
- Process Engineer

...question 80...

An attacker has a goal of obtaining information stored in an ICS. Why might the attacker focus his efforts on the operating system rather than the ICS application

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

- The operating system will have fewer vulnerabilities than the ICS application
- Control of the operating system offers access to applications running on it
- Organizations generally do not define a role or responsibility for dealing with operating systems, leaving them negiected and vulnerable
- The ICS is more likely to have vendor-provided security hardening guidance than the operating system will

question 81...

An administrator wants to script the deployment of a security policy on a group of workstations not managed by Active Directory. What tool colud be used to accomplish this task?

- Secpool.msc
- Gpedit.msc
- Svw.exe
- Secedit.exe

question 82

which of the following is a protocol that will provide control center-to-control center SCADA communications in a situation where each of the control centers implement a different vendor-supplied protocol internally?

DNP3

BACnet

MMS

Modbus/TCP

ICCP

question 83

question 84

question 85

Which of the following relies on three geostationary I-4 satallites and provides three different types of service

- LTE
- CDMA
- VSAT
- GSM
- BGAN

question 86

Which of the following was a method used by Stuxnet to replicate itself to other

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

- Fuzzed input fields
- Windows RPC
- Windows OLE
- Crafted input signals

question 87

Which type of server would be deployed to provide stratum level 2 clock synchronization ICS system?

- ARP
- TFTP
- PTP
- RADIUS

question 88

Which of the following is a term used to describe systems which control, monitor, and manage industrial processes that are dispersed but operated as a coupled system?

- Process Control Sytstem (PCS)
- Distributed Control System (DCS)
- Safety Instrumented System (SIS)

question 89...

For a SQL injection login authentication bypass to work on a website, it will ..... username comparison that the database finds to be true. What else is requri..... bypass to work?

- An unencrypted login page
- The databese's comment characters
- Two pipe characters (||)
- The correct password

question 90

Which of the following technologies is prone to a fake base transceiver station at....

- GSM
- BGAN
- ZigBee
- CDMA

question 91

An engineer at Acme Co. has found an ICS supplier security advisory on one of their vendor's websites. What kind of information would be expected in this document?

- A time-frame for when the risk should be patched
- An explanation of why the risk should be accepted or mitigated
- An evaluatiin of the risk versus the risk tolerance level
- A summary of the risk and impact

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

question 92…

What is a recommended practice for securing historians and databases whose purpose is to feed data back into the control processes?

- Use reliable network protocols like HTTP for remote management
- Use a dedicated domain admin user account to manage databases
- Audit both successful and failed login attempts to databases
- Facilitate auditing by placing historians and databases in the same DMZ

question 93

Given the following ACL entry, what would be the result of a TCP packet sent throught the firewall to a web server listening on port 80?

sudo iptables -A INPUT -p tcp –dport http -j REJECT

- The packet would be blocked and no response sent to the source host
- The packet would be blocked and ICMP message returned to the source host
- The packet would be blocked and an alert sent to the destination host
- The packet would be blocked but any reply will be blocked outbpund

question 94

What is a characteristic of the Ladder Diagram approach for programming controllers?

- May be similar to high level computer programming languages like C
- Uses steps to execute commands and transitions to wait for conditions to move forward
- Based on circuit diagrams of relay logic hardware and operates on rules rather tan procedures
- Is similar to a low level programming language like assembly

question 95

When cybersecurity is the driver for choosing what logs to capture, which of the following would provide the best approach to windows event logging?

- Begin with all auditing turned on then turn off items you determine you don’t need
- Begin with a list suggested by a busşness unit survey of what is important
- Begin with the default windows list and only modify it if absolutely necessary
- Begin with a minimum set then add to it as your processes evolve

question 96

In the context of ICS the process of fuzzing a device is described as which of the following?

- Brute force password attacks against default accounts
- Monitring device performance in varying power conditions
- Monitoring deviceperformance in harsh environmental conditions
- Launching all known exploits at the device in a randromized sequence
- Providing invalid, unexpected, or random data as inputs

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

question 97

question 98

Which of the following system hardening steps applies to embedded devices to be deployed in the critical infrastructure sector as well as common business IT infrastructure?

- Apply patches as soon as they ara available from the manufacturer
- Install and configure a network honeypot
- Install a siem on the device or system
- Disable or remove unnecessary usernames and password

question 99...

Which requirement would WirelessHART be able to address?

- Access to a remote site using a cellular provider's network
- Preventing rogue devices froom sppofing authorized network devices
- Access to a remote site with support for IPv6 addressing
- Preventing unauthorized MAC addresses from joining the network

question 100

What is the IP address range 192.200.1.0/24 defined as?

- Public network
- Private network
- Invalid network
- Multicast network

question 101...

what will the following command accomplish?

Wmic.exe /node:10.4.3.23 STARTUP list full

- Print a list of applications that are running on a remote host
- Query the registry run key for applications that will start on boot
- Show a list of workstations that have connected to the node since startup
- Display the service pack and version of the host when the workstation last booted

question 102...

Which of the following is a team of incident responders that often coordinate with organizations and law enforcement to reduce risks and advise on security threats?

- CERT
- COBIT
- CVE
- CVSS

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

question 103…

An organization has their ICS operations and networking equipment installed in thePurdue model level 3. Where should the SIEM for this equipment be placed in relation to the existing Level 3 devices?

- On a management subnet in level 4
- On a management subnet in level 2
- On the same subnet in level 3
- On a different subnet in level 3

question 104

Which of the following refers to how long a system can be unavailable when recovering from a business outage or natural disaster?

- BCP
- RPO
- RTO
- DRP

question 105

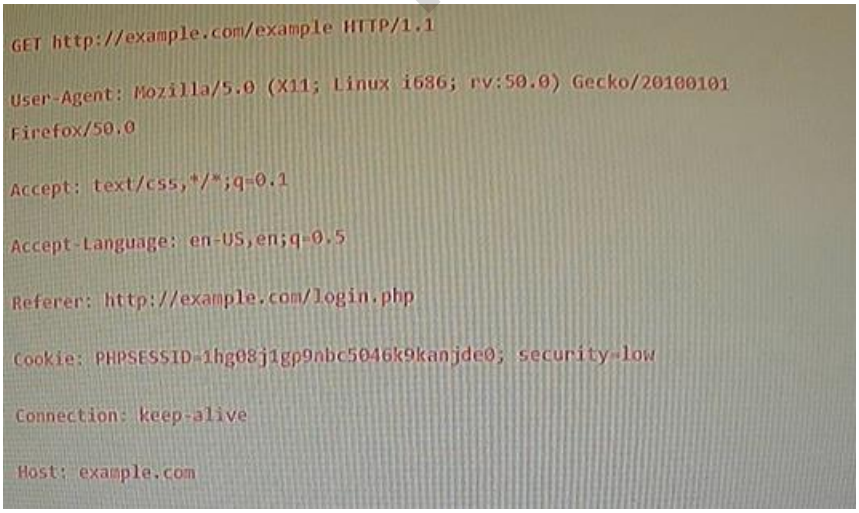
Which of the following takes a time stamped measurement from a local grid to help track grid stability?

- PMU
- PLC
- RTU
- GPS

question 106

question 107..:

An attacker was able to modify the cookie value shown below to that of an authenticated user, what type of attack did they use to exploit the web application?



Get HHTP://example.com/example HTTP/1.1

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

User-Agent: mozilla/5.0 8x11; linux i686; rc:50.0) Gecko/20100101 firefox/50.0

Accept text/css, */*; q=0.1

Referrer: http://example.com/login.php

Cookie: PHPSESSID=lhg08jlgp9nbc5046k9kanjde0; security=low

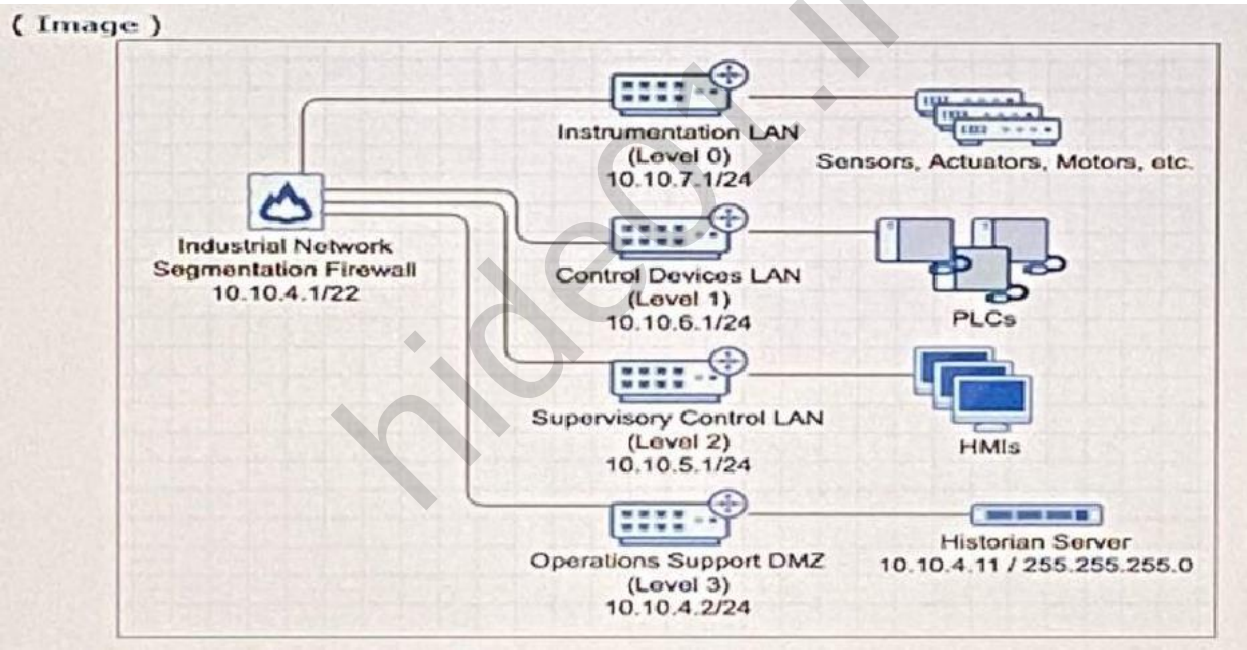
Connection: keep-alive

Host: example.com

- Cross-Site Request Forgery
- Cross-Site Scripting
- Session Hijacking
- Local File Innclusion

question 108

Which Factor would negate the ability to use 802.1x on the 10.10.7.1/24 network?



- The official wireless network was implemented with wpa2 enterprise
- Lack of granualirty in vlan access control lists
- Network limitations require backwards compatibility with telnet
- Devices on 10.10.7.1/24 cannot use EAP

question 109

İmplementation of LDAP to manage-and control- access to your systems which nist csf core function

- Identify

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

- Protect
- Detect
- Respond

question 110

What is a common characteristic of a rogue access point?

- It uses an unencrypted signal
- It uses WPA2 to avoid detection
- It extends the 802.1x protocol
- It uses TTLS for authentication

question 111

question 112

question 113

What mechanism could help defeat an attacker's attempt to hide evidence of his/her actions on the target system

- Centralized logging
- Sandboxing
- Attack surface analysis
- Application allow lists

question 114

Which of the following programs is intended to overwrite Local Security Policies on Windows host?

- HIDS
- Gpmc.msc
- Cmd.exe
- Exploit Guard

question 115

In Which phase of the six step incident handling process would the task of creating escrow for passwords and encryption keys be found?

- Lessons learned
- Recovery
- Identification
- Preparation

No question number

Based on the following diagram, how many Active Directory domains should be created for this network ?

- Two separate domains without a trust relationship
- Two separate domains within the same tree

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

- One domain with separate groups within
- One domain with transitive trust

77 no question 77



- Main-in-the-middle
- Backdoors / auth bypass
- Brute force
- Fuzzing

68 no question number 68

Observe the network diagram. Which of the following hosts is intended to keep ICS process data in a database?

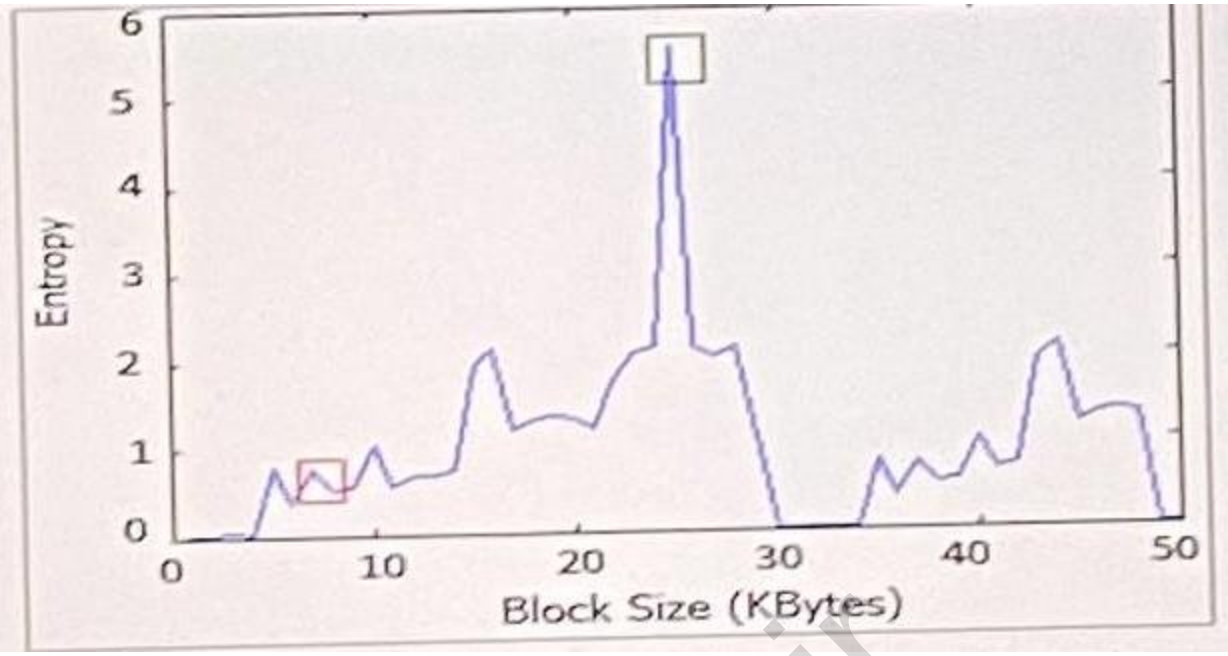
- 10.10.3.17
- 10.10.4.239
- 10.10.4.11

83 no question number 8384…

Which of the following is indicated by the spike in entropy, shown in the graph below, during a review of flash dataset?

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit



- Buffer overflow
- Data upload
- Cryptographic keys
- Plaintext strings

53 no question 53

- File print and application servers in level 4 business network
- Vendor server in level 2/3 support & supervisory network
- Direct vendor connection to firewall
- Engineering workstation in level 4 business network

No question

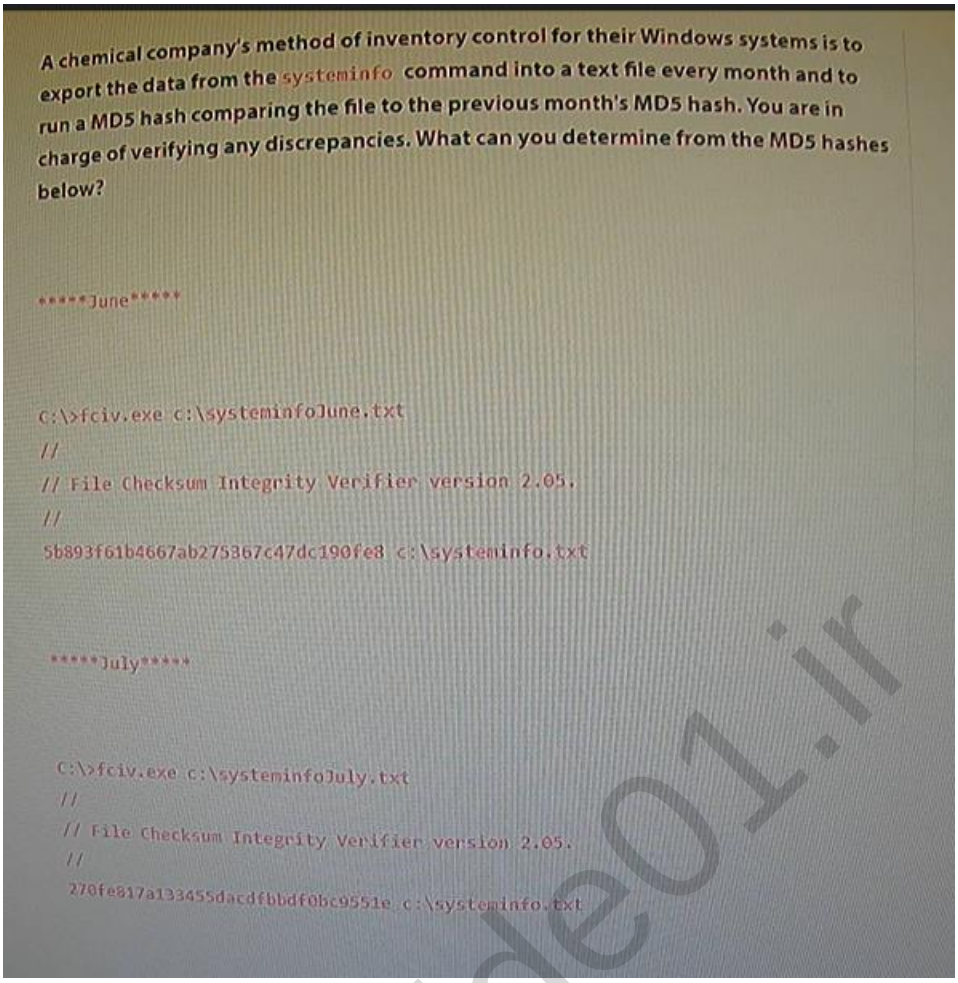
- There was a large change in the file from June to July
- There was a small change in the file from June to july
- There was a change in the file from June to July
- There was a complete replacement of data from June to July7

84 ...

A chemical company s method of inventory contro ort e r indows systems is to export the data from the systeminfo command into a text file every month and to run a MD5 hash comparing the file to the previous month's MD5 hash. You are in charge of verifying any discrepancies. What can you determine from the MD5 hashes below?

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit



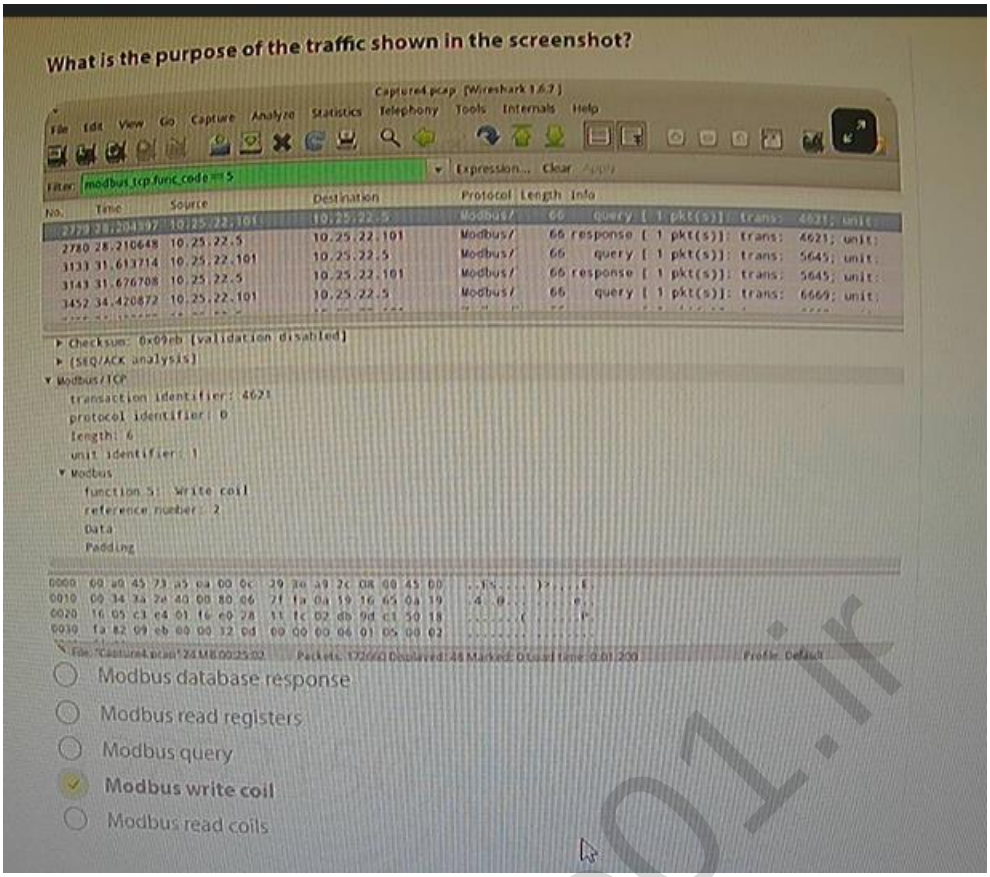
- Graph the most common human readable words identified in the memory file
- Modify the memory dump file to substitute specific letters in the output
- Convert the memory image to different formats prior to execution
- Search the memory image for certain types of character encoding

70 no question 70

What is the purpose of the traffic shown in the screenshot?

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit



- Modbus read registers
- Modbus write coil
- Modbus query
- Modbus read coil
- Modbus database response

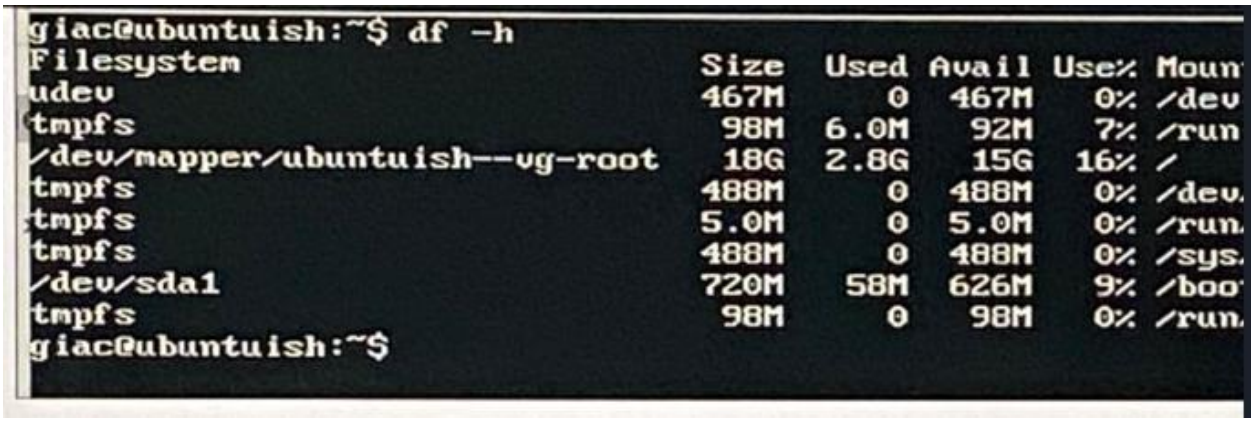
97 no question 97

- Transport
- Internet
- Network
- Data Link

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

33 no question 33



- A shadow file system is being used on the workstation that is occupying the remaining space
- A root kit installed that is displaying false information to the console
- The application has well known a rounding error when displaying the contents of drives that exceed 15 gb
- The system is reserving a small percentage of the capacity for emergency writes

Second Exam Questions

Question

Which of the following is typically performed during the Recovery phase of incident response?

- Updating the organization's security policies to prevent future breaches.
- Making a forensic image of the system(s) involved in the incident.
- Finding the coot cause or vector used by the attacker to gain entry and maintain access.
- Patching and configuring systems to meet established secure configuration standards.

Question...

What approach can an organization use to make sure that high consequence, low probability risks are considered during risk analysis?

- Prioritize risks based on mitigation cost
- Prioritize risks based on impact
- Give likelihood a higher weight
- Give frequency a higher weight

Question

Which of the following would be considered a Purdue level 0/1 attack surface?

- Vulnerable firmware on a firewall
- Webserver used to configure a PLC
- RS-232 interface on an engineering workstation
- The I'T:ndcnvs or Linux kernel

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

Question

Which of the following is a benefit of using single sign-on?

- Reduces the need for password comp!exity
- Simplifies user management
- Eliminates the need for mufti-factor authentication
- mitigates password cracking attacks

question..

What method is used to determine the maximum tolerable downtime for the firewall that is segmenting the Operations Support zone from the Supervisory Control LAN?

- Business impact analysis
- Disaster recovery planning
- Business continuity planning

Question

Which resource includes a standardized categorization of common software vulnerabilities?

- csc
- cvss
- cwe
- cip

question

Which type of process performs an action on a set quantity of material at one station before moving it to the next station for another action to be performed on it?

- Continuous
- Batch
- Hybrid
- Discrete

Question

An attacker goes to www.MyCoolSite.com and is asked for a password, so they try www.MyCoolSite.com/cool, www.MyCoolSite.com/cooler, and www.MyCoolSite.com/coolest. Each time they are asked for a password. Finally the attacker tries www.MyCoolSite.com/secret and obtains access to www.MyCoolSite.com. Which kind of exploit is this?

- SQL injection
- Password brute-force
- Cross-site request forgery
- Authentication bypass

Question

Which of the following statements best describes how a security policy should be

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

written?

- It should be direct, concise, and easily readable by those expected to follow it
- It should be written in formal, legal language similar to a business contract between uvo parties
- It should be as comprehensive as possible, and cover every possible contingency in as much detail as possible

Question

What information can be found by dumping data at rest from a Purdue Enterprise Reference Architecture level 0/1 device?

- Firmware on read-protected chip
- Frequency-hopping algorithm that the RF chip will use
- Static cryptographic keys

Question

An ICS network design requires the ability to transmit data from historians on the operations network to a read-only database on the business network. The data is used for analysis and accounting. Which of the following security controls should be used to implement this network communication requirement securely?

- Unidirectional Gateway
- Transport Layer Security
- Network Access Control
- Virtual Private Network

Question

Which character pattern in EEPROM or flash data could indicate the presence of

asymmetrical cryptographic keys?

- Long strings of non-printable characters
- Non-printab!e data represented by periods
- Blocks of repeating characters
- Large series of randomized printable characters

Question…

At what level of the Purdue model would a supervisory system for a local process be found?

- Level 3
- Level 1
- Level 4
- Level 2
- Level 0

Question…

During testing of a new web application, the QA analyst notices that a database exception is thrown when a single quote character is entered as part of the username in the login box, but no error occurs

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

when it is entered as part of the password. Based on this information only, what is a reasonable explanation regarding this behavior?

- Cross-site scripting attacks may be possible, allowing an attacker to bypass the login and impersonate users
- Cross-site request forgery may be possible, allowing an attacker to access valid usernames and password information
- SQL injection may be possible, allowing an attacker to access vaticl usernames, but passwords are protected
- SQL injection may be possible, allowing an attacker to access valid usernames and passwords information

Question…

What is the best option for applying Microsoft security templates?

- Using a centralized WSUS server
- Editing the registry
- Scripting with Task Scheduler
- Using the SCA snap-in

Question

Which of the following is a team of incident responders that often coordinate with

organizations and law enforcement to reduce risks and advise on security threats?

- COBIT
- cvss
- CERT

Question

A brewer uses a local HMI to communicate with a controller that opens a pump to

move the wort from the boil kettle to the fermentor. What level of the Purdue model

would the controller be considered?

Level 0

Level 2

Level 4

Level 3

level 1

question

Which characteristic indicates the presence of an unencoded RSA key when using an

entropy graphing tool on an EEPROM memory sample?

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

- A spike in the randomness of the data
- A series of peaks and valleys
- An elliptical curve in the data
- A flat section of blocks within the data

Question

Understanding current threats and their risk to organizational operations is part of which NIST CSF (cybersecurity framework) function?

- Respond
- Detect
- Protect
- Identify

Question

Which feature is added when moving from Windows 7 to Windows 10?

- Device Guard
- BitLocker Drive Encryption
- User Account Control
- Advanced Firewall

Question

Which of the following is typically performed during the Recovery phase of incident

response?

- Updating the organization's security policies to prevent future breaches.
- Making a forensic image of the system(s) involved in the incident.
- Finding the root cause or vector used by the attacker to gain entry and maintain access.
- Patching and configuring systems to meet established secure configuration standards.

Question

What data would an attacker have access to if they compromised the runtime database of a DCS?

- Setpoints
- Project files
- Event togs
- Passwords

Question

Which attack would be possible as a direct result of an ICS device accepting unauthenticated commands?

- Spoofing
- Buffer overflow
- Sniffing

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

- Backdoor

Question…

A plant is being retrofitted with new cyber security devices in Purdue Level 3. What should the network security architect suggest for the installation?

- Move the cyber security devices to a DMZ
- Add a firewall to segregate the cyber security devices
- Place the cyber security devices on their own subnet

Question

Which of the following is located in user mode of a typical real-time OS, but in kernel mode of a typical standard OS?

- Virtual memory
- Process scheduling
- Device drivers
- Interprocess communication

Question….

Which of the following is part of the Respond function of the NIST CSF (cybersecurity framework)?

- Restoring from backup a system that had been compromised
- Performing forensics analysis on a system and eradicating malware
- Discovering malicious activity on the network using multiple sensors
- Limiting user access to only those netwolk resources necessary for them to do their jobs

hide01.ir

EXTRA -Test Exam questions

Question 3

Which Tool can an attacker employ to brute force an encryption key password from a memory dump within a pcap file?
(Answer)
Zbgoodfind

(Question 1)

How could an administrator applv security policies to Windows machines that are not part of an Active Directory domain?
(Answer)
Delivering a template with secedit.exe

(Question 2)

Which of the following contains tine logic and parameters for Programmable Logic Controllers (PLCs)?
(Answer)

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

Project Files

(Question 14)

What is the function of a safety system (for example an SIS integrated into a plant's DCS)?
(Answer)
Provide predictable and timely fail-safe shutdown of the process

(Question 115)

Which of the following is the most direct threat to an air-gapped system?
(Answer)
USB thumb drive containing malware

(Question 114)

For Active Directory, which is the function that manages the password policy such as length of password or expiration date?
(Answer)
Group policy

(Question 113)

Which role will social engineers target if their intent is to gather information about control logic in use at their target company?
(Answer)
programmer

(Question 112)

Which of the following is a monolithic protocol?
(Answer)
ModbusRTU

(Question 111)

Which of the following is a reason to avoid symmetric stream ciphers?
(Answer)
Management overhead

(Question 110)

Which of the following can be used to determine vulnerabilities in order to develop a Business Continuity Plan and DR Strategy?
(Answer)
Risk Analysis

(Question 109)

During a disaster recovery test a remote administration workstation that was left open to facilitate offsite engineers recovering a SAN fabric is compromised by a hacker. Which of the following does the firm need to ensure during the BCP/DR process?

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

(Answer)
Security controls

(Question 108)

A vendor is remotely connected to a client's HMI workstation. The vendor is browsing a popular forum to assist in troubleshooting the HMI. The vendor accidentally clicked on the following hidden link and valve 41234 in the plant closed. What kind of attack was this?
http://hmi.SillyVendor.com/close?valve=11234
(Answer)
Cross-site request forgery

(Question 107)

Which of the following Tools can discover Internet-facing control systems?
(Answer)
Shodan

(Question 106)

Which of the following IEEE standards specifies a framework for network authentication?
(Answer)
802.1x

(Question 105)

Which of the following satellite communication platforms would provide reliable data, phone, and video services for a fixed, remote SCADA site with multiple users and devices?
(Answer)
Very Small Aperture Terminal

(Question 104)

Which of the following can assist in implementing single sign-on authentication by using a ticketing system?
(Answer)
Kerberos

(Question 102)

When conducting a cyber investigation, what would the security team do as part of the System and Configuration Check process?
(Answer)
Review event logs and look for new user accounts

(Question 100)

Who is responsible to ensure an ICS meets security requirements in the field?
(Answer)
Asset owners

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

(Question 99)

Which of the following describes a technique in which a log file is automatically renamed for longer term, compressed storage at regular specified intervals thereby allowing logging to continue to a smaller file that will not fill up the file system?

(Answer)

Log rotation

(Question 98)

Which of the following tasks would be done during the preparation phase of the incident handling process?

(Answer)

An incident handler testing a restore process checklist

(Question 97)

An attacker is able to adjust settings on a GPO that will be pushed out across all workstations. What is the maximum amount of time before workstations will download the malicious GPOs?

(Answer)

120 minutes

(Question 96)

Which of the following database types feed data into ICS processes?

(Answer)

Formula

(Question 95)

What advantage does the NIST CSF have over the ISO 27001 and ISA/IEC 62443 cybersecurity frameworks?

(Answer)

Is available to any organization without cost

(Question 94)

If a single loss expectancy is equal to $30,000 with an exposure factor of 30%, what is the value of the asset?

(Answer)

$100,000

(Question 93)

Which of the following rules will allow an outbound SSH connection to be created?

(Answer)

İptables -A INPUT 10.10.50.0/24 -p tcp --sport 22 --state ESTABLISHED,RELATED -j ACCEPT

(Question 92)

The security team determined that an attacker was able to directly access a web server's backend database, which uses the Linux operating system. What input could the attacker have entered on the login web page to determine if the application was vulnerable to SQL injection?

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

(Answer)
A single quote in the username field, and a random character string in the password field

(Question 91)

What is a characteristic of a Programmable Logic Controller (PLC)?
(Answer)
Read inputs and adjust the outputs accordingly

(Question 90)

What can you derive from the following screen capture?
sha1sum file5.txt
6476df3aac780622368173fese768â2edt3932t8 file5.txt
sha1sum file6.txt
6476df3aac7806223681 73f26276M2edc3932c8 file6.txt
(Answer)
The contents of file5.txt are exactly the same as file6.txt

(Question 88)

Which event should cause an analyst to review facility video recordings for a physical intrusion?

- The communication link between the main control room and the spent fuel pool went down
- A temperature sensor recently made an unexplained connection to a valve
- The custodian requested a new key because their old one stopped working
- The system administrator found an unauthorized account on the domain controller

(Question 87)

Which of the following message security properties does a digital signature provide In the context of public-key cryptography?

- Non-repudiation and confidentiality
- Confidentiality and integrity
- Integrity and availability
- integrity and non-repudiation

(Question 103)

Observe the network map. A SIEM server will be deployed using ANSI/lSA-99/lEC-62443 standards. Into which subnet will the SIEM server be placed?

10.10.4.0/24

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

(Question 26)

If Modbus TCP were mapped to the OSI network model, in which layer would the Modbus client hex encode a request?

- Session
- Network
- Presentation
- Transport

Question 25

Which of the following physical threat actors is the hardest to detect?

(Answer)

Thief

Vandal

Disgruntled employee

Terrorist

New questions

1

Implementing VLANs can provide which of the following?

A) Segmenting control device traffic from other network services

B) Stopping unauthorized access to ICS controller diagnostic ports

C) Sandboxing ICS application memory from other system resources

D) Separation of duties for different guest OSes on a virtual host

2 No answer option

Based on the following diagram, how many Active Directory domains should be created for this network?

3

Which of the following devices would indicate an enforcement boundary?

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

A switch with VLANs

An application with a login screen

A workstation with antivirus

A router with ACLs

4

How is a WirelessHART enabled device authenticated?

C) Using the vendor hard-coded master key to obtain a link key

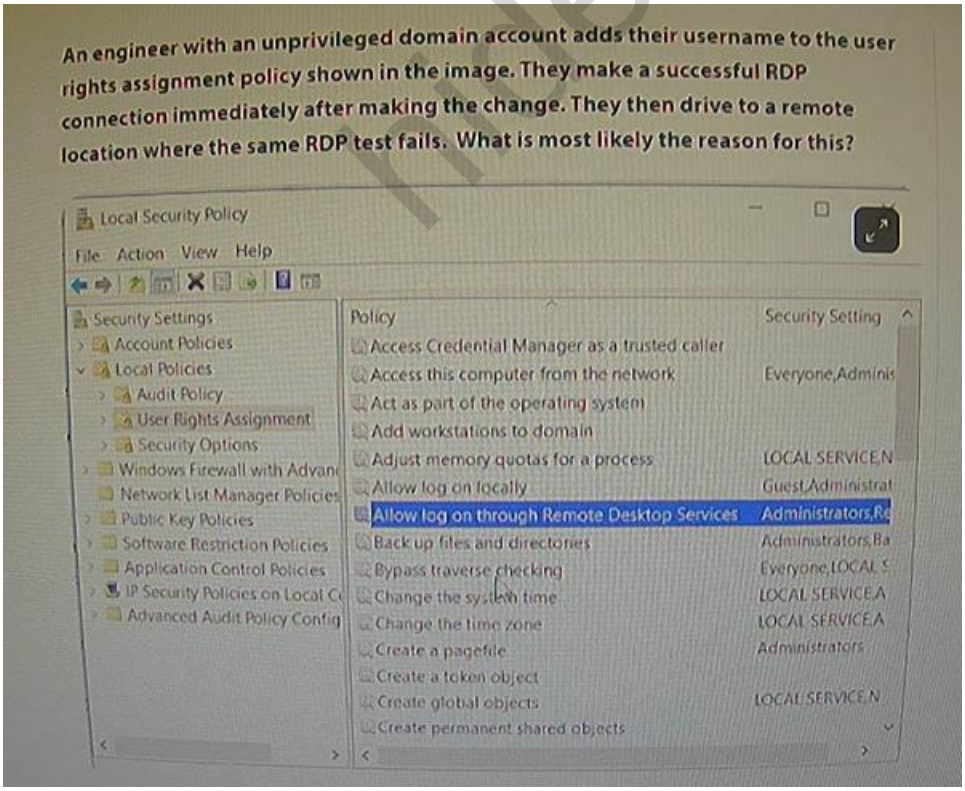
C) Using a PIN combined with the device MAC address

C) Using a join key to send an encrypted request for the shared network key

C) Using a WPA2 pre-sharedkey entered by an administrator

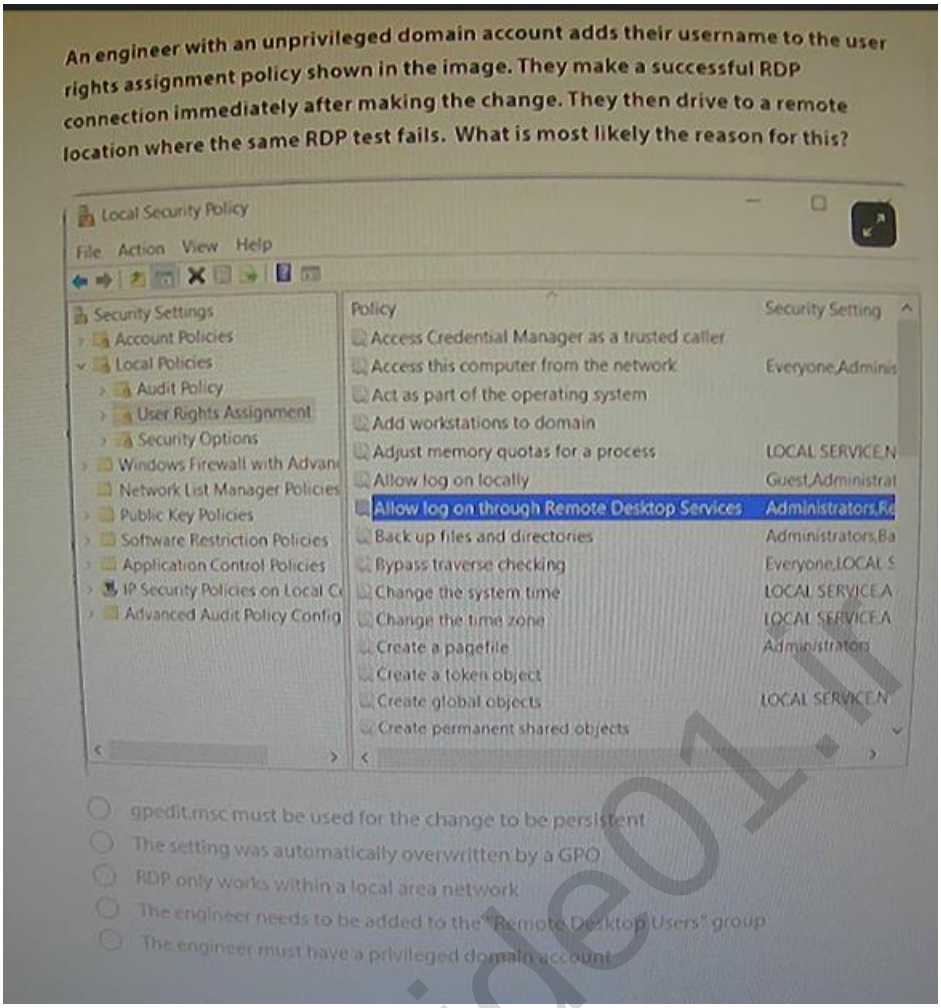
5

An engineer with an unprivileged domain account adds their username to the user rights assignment policy shown in the image. They make a successful RDP connection immediately after making the change. They then drive to a remote location where the same RDP test fails. What is most likely the reason for this?



hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit



qpedit.msc must be used for the change to be persistent

the setting was automatically over written by a GPO

ROP only wotks within local area network

enqineer needs to be added to the Elkernote Desktop qtoup

hove a ptivi!egecl dornain account

6

Which document should be updated to include incident handling while in the Planning phase of incident response?

A) Backup policy

B) Access control policy

C) Disaster recovery planf

D) Vulnerability'report

7

What is a benefit of MECM over WSUS?

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

Lower configuration and management overhead

Minimal system resource use

tower operating and proåuct Cost

Hardware and software inventory control

8

Martin is writing a document that describes in general terms how to secure embedded operating systems. The document includes issues that are specific to embedded devices vs desktop and laptop operating systems. However, it does not call out specific flavors and versions of embedded operating systems. Which type of document is Martin writing?

Policy

Guideline

Standard

Procedure

9

At which level of the Purdue model would a plant-wide supervisory system belong

Level

Level 5

level 3

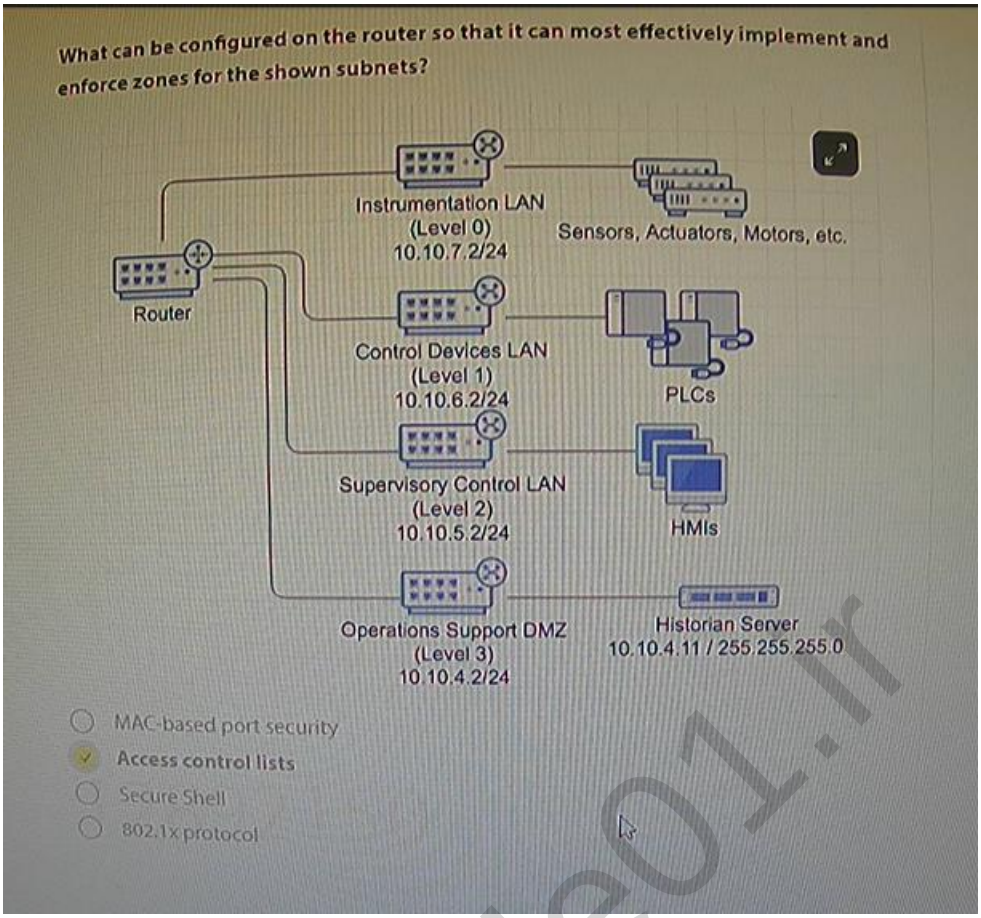
[evel 1

10

What can be configured on the router so that it can most effectively implement and enforce zones for the shown subnets?

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit



11

How are general purpose Programmable Logic Controllers (PLC) different than smart field devices?

A) Smart field devices contain their own control logic that cannot be changed

b) Programmable Logic Controllers have a more limited purpose and function

C) Smart field device> capnol be controlled centrally from a management server

d) Programmable Logic Controjters are usually microcontroller-based

12

An organization wants to use Active D rectory o manage systems within its Business and Control system networks. Which of the following is the recommended security practice?

A) An Active Directory domain for the Business network and a Windows workgroup with a domain controller for the Control system network

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

B) Separatenctive Diqectorydomains for the Business and Control system networks

C) Shared Active Directory with fully functional domain controllers for the Business network and a Read-Only Domain Controller for the Control system network

D) Shared Active Directory domain with separate domain controllers for the Business and Control system networks

13

During a plant upgrade an architect needs to connect legacy IEDs to a new TCP/IP instrumentation LAN. The IEDs only have RS-232 communication intefaces available. What would best be used to connect the IEDs?

a) Communications Gateway

b) Data diode

c) Engineering worKStation'

d) Industrial switch

14

How can virtualization be leveraged in an ICS environment?

a- Testing new patches
b- b- Increasing networking speed
c- c- Increasing processing speed
d- d- Sharing hardware resources across security levels

15

Which type of device is the following configuration setting from? deny modbus function writ:e-multiple-holdin GREGİSTERS
A) Network firewall
B) SIEM
C) NIDS
D) Apptication firewall

16

How can remote file inclusion be defended against?

A)Avoid direct relationships between user input and filenames

b)Avoid using weak passwords

C)Enforce strong encryptionfor remote access

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

D)Ensure cookies expire when they are no longer needed

17

What is an output of a Business Impact Analysis?

A Determining the maximum time that systems can be offline

B Prioritizing the business's processes

C Understanding all of the busi ess's technology functions

D Calculating the financial impact of a technology failure

18

Which type of process is described below?

Ten barrels of hot water is moved from the hot liquor tank to the tun.

5OO kg of milled grist is added to the mash tun.

The mixture is maintained for 60 minutes before being drained to the boil kettle.

A) Distributed

b) Batch

c) Continuous

d)Discrete

19

Which type of process is used to manufacture fuels, chemicals, and plastics?

A) Continuous

B) Batch

C) Discrete

20

Which of the following is a component of both a traditional kernel and a real-time operating system kernel (RTOS)?

A) Device Drivers and Dispatchers

B) [ile Management

C) Application Interp!occss Comm0nication

D) Virtual Memory ånd Scheduling

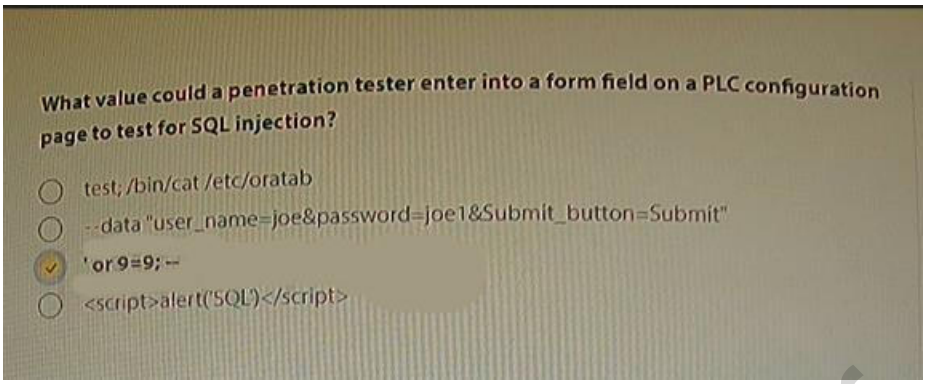
hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

21

What value could a penetration tester enter into a form field on a PLC configuration

page to test for SQL injection?



test; /bin/cat /etc/oratdb

-data I

' or 9=9;

22

Due to reliability and availability issues with some sites located around the globe, you need to enable field sites to communicate directly with each other without needing to go through the corporate headquarter LAN or other central site. Which WAN technology would allow this configuration

A VSAT

b Microwave

c RS232 !

d 802.11n

23

Which type of document would recommend a best practice?

Procedure

Policy

Guideline

Standard

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

24

When used as an Enforcement Zone Device, data diodes provide which of the

following paths of communications to achieve best practices?

a Bidirectional between supervisory and control environments

b Bidirectional between business and control zones

c Unidirectional in or out ofa control environment

d Unidiiectional within supervisory/HMl zones

25

What type of physical security control is a procedure that details what to do in the

A) Delaying

B) Deterrence

C) Responsive

D) Detective

26

When calculating risk, which of the following is hardest to predict?

A) frequency of an event

B) Percentage of [oss

c) Asset Value

D) Single Loss Expectancy

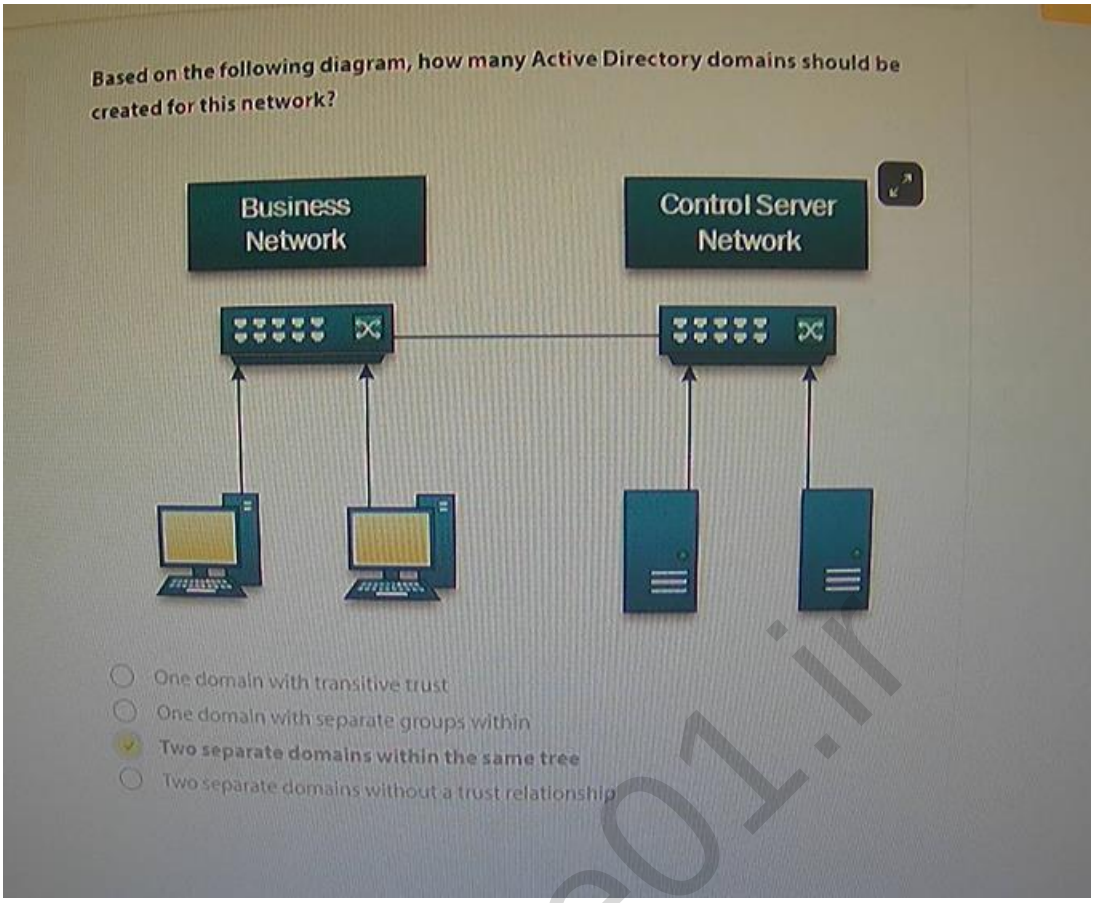
27

Based on the following diagram, how many Active Directory domains should be

created for this network?

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit



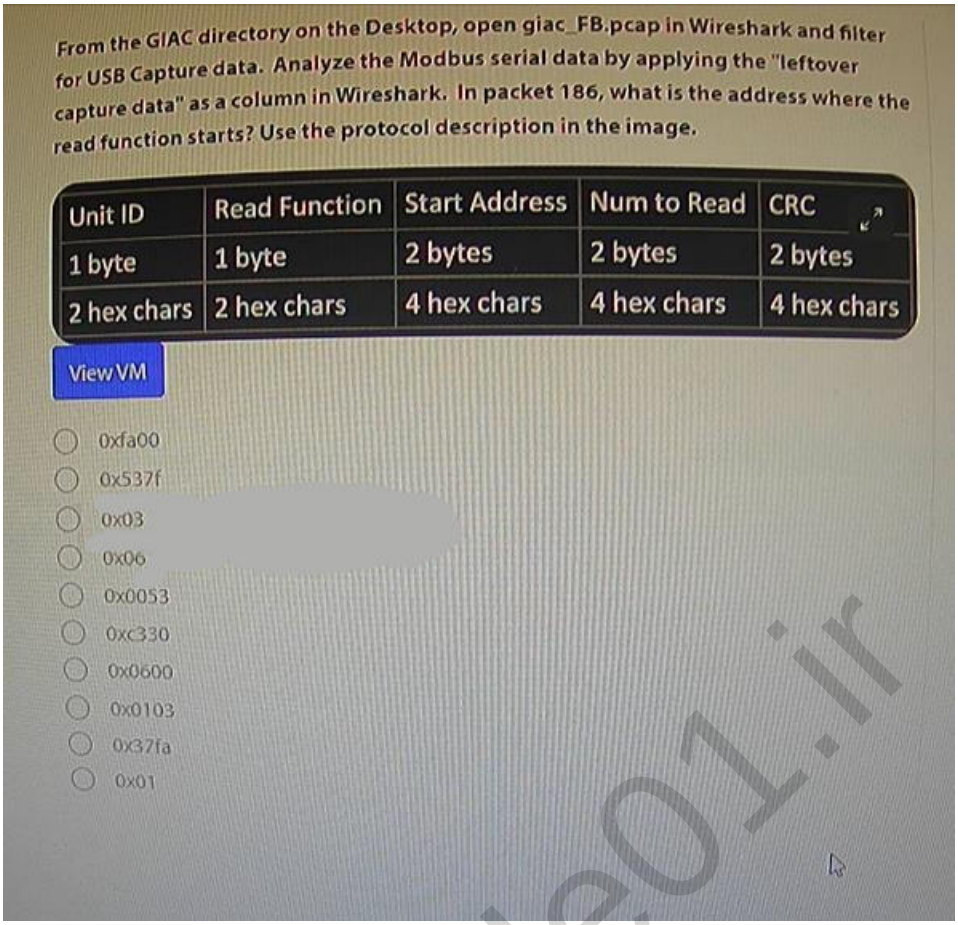
Practical Questions

1

From the GIAC directory on the Desktop, open giac_FB.pcap in Wireshark and filter for USB Capture data. Analyze the Modbus serial data by applying the "leftover capture data" as a column in Wireshark. In packet 186, what is the address where the read function starts? Use the protocol description in the image.

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit



0x0600

2

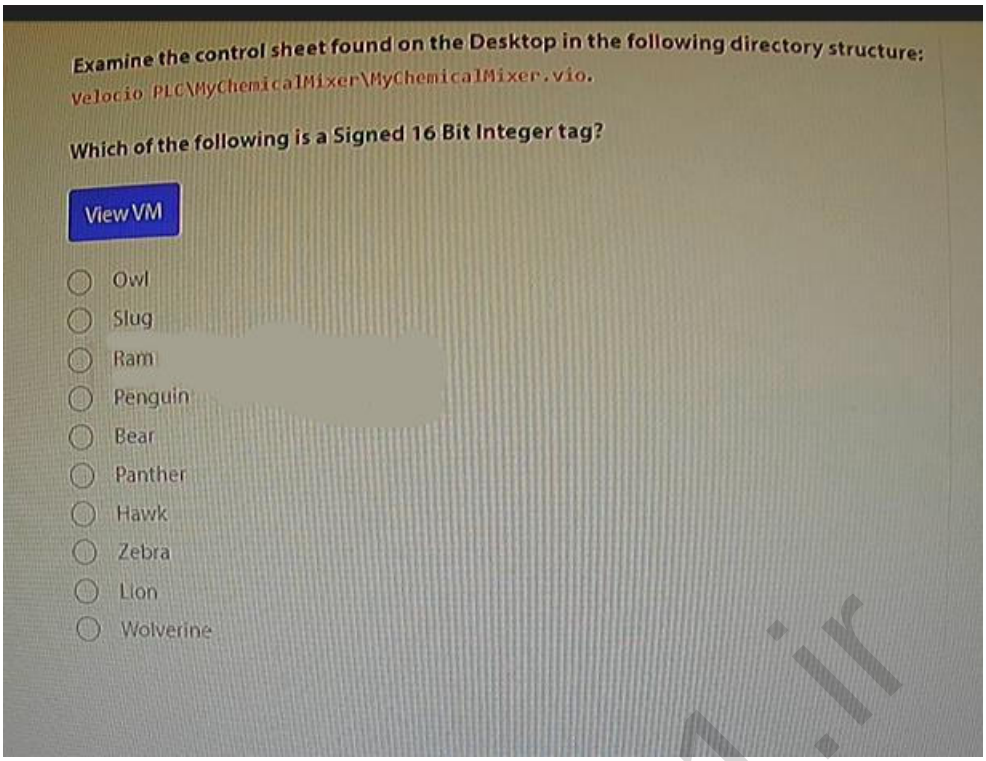
Examine the control sheet found on the Desktop following directory structure:

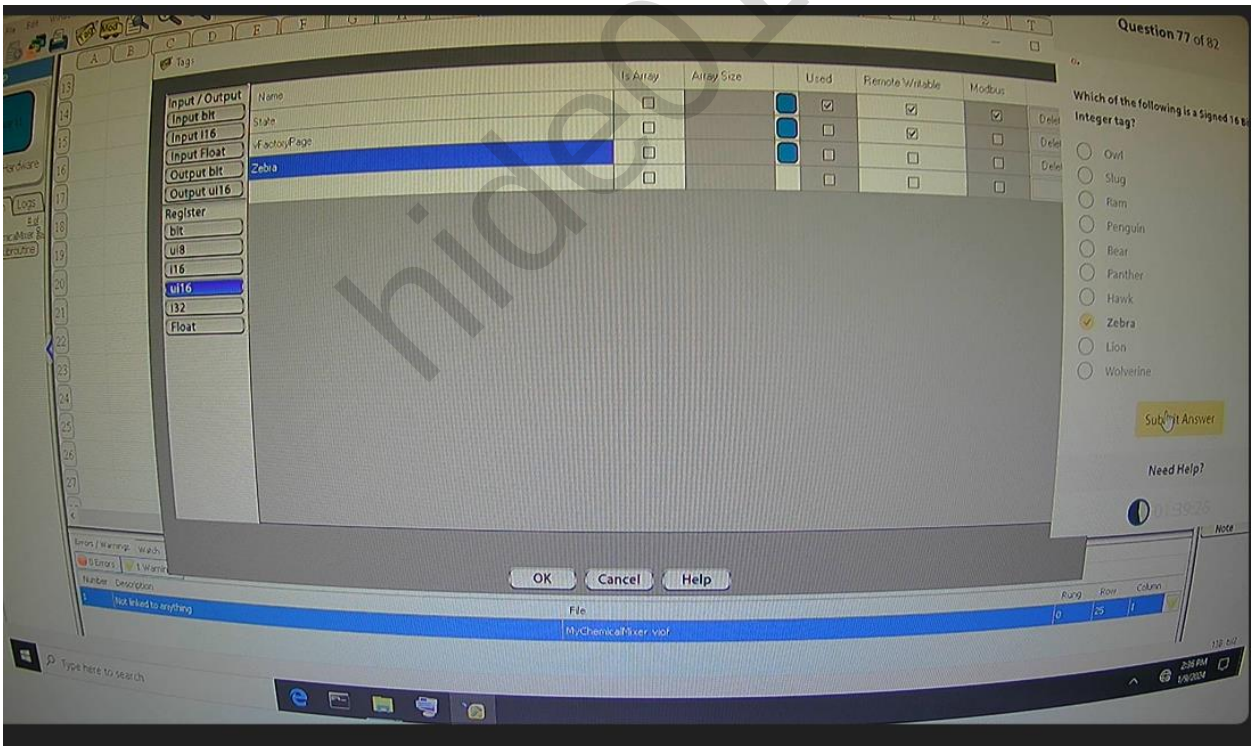
Velocio plc\

Which of the following is a Signed 16 Bit Integer tag?

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit



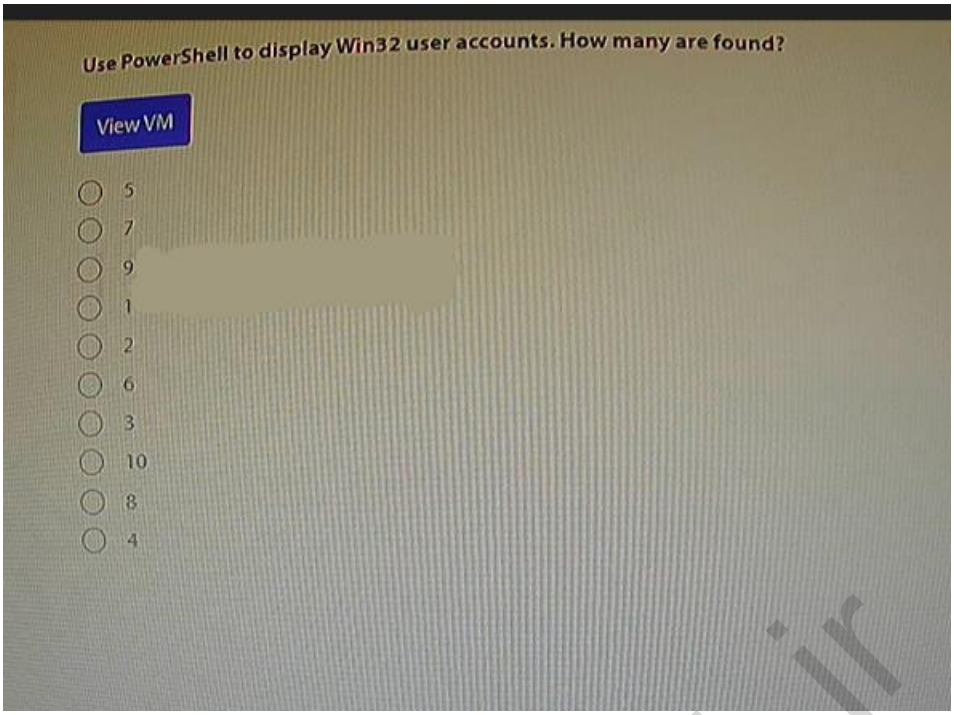


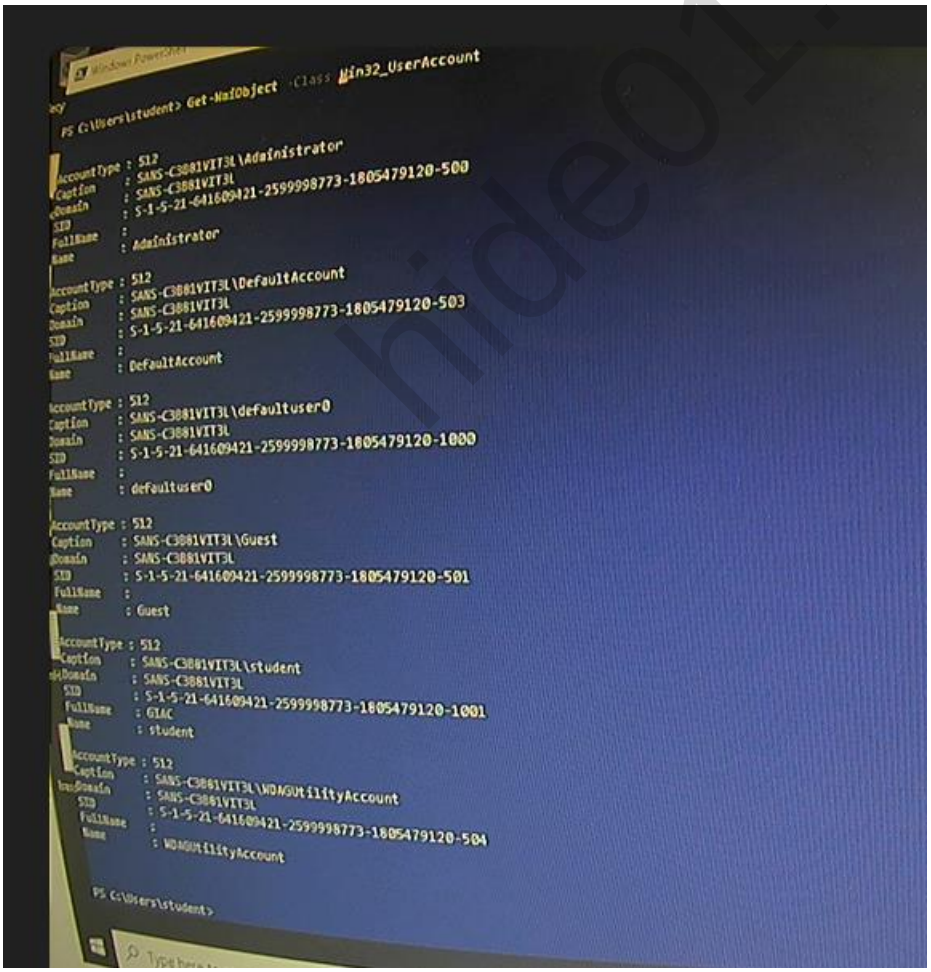
zebra

3

Use PowerShell to display Win32 user accounts. How many are found?

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit





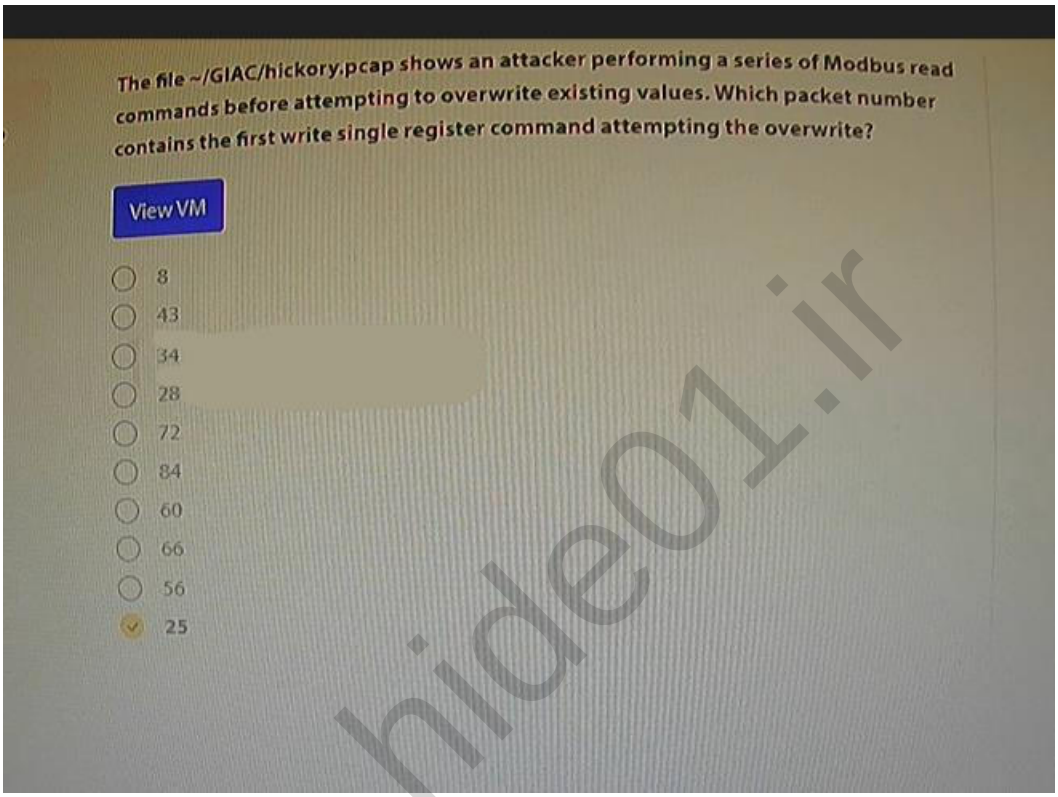
hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

Answer –> Get-WmiObject -Class Win32_UserAccount

4

The file N/GIAC/hickory.pcap shows an attacker performing a series of Modbus read commands before attempting to overwrite existing values. Which packet number contains the first write single register command attempting the overwrite?

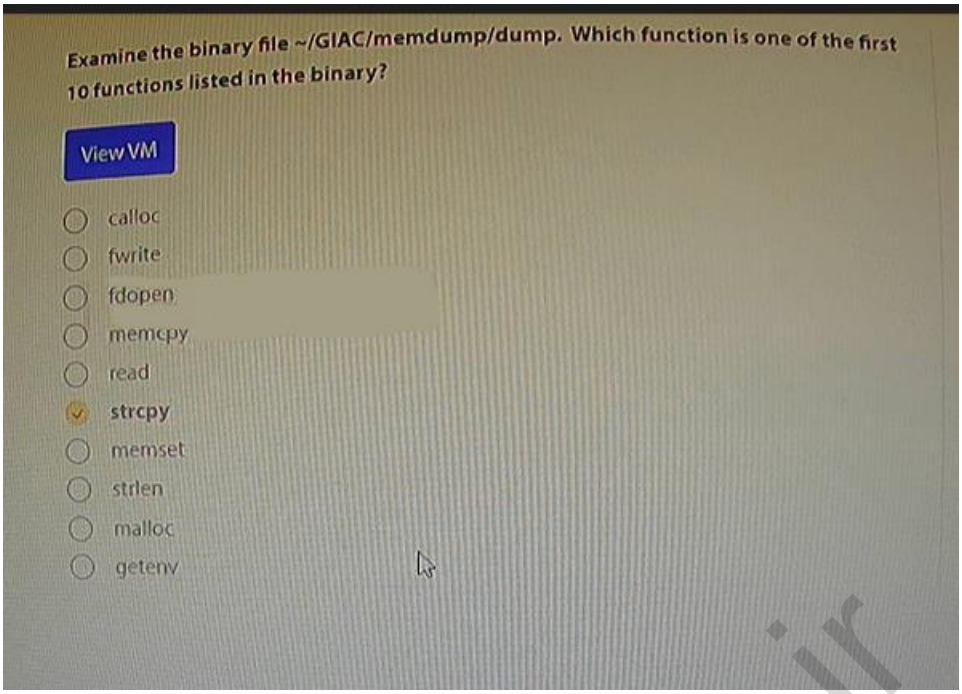


5

Examine the binary file —/GIAC/memdump/dump. Which function is one of the first

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit



6

Answer

A file was encrypted using the following command and a passkey of "giacpass". Derive the PBKDF2 key in CyberChef. What are the last four characters of the key?

openssl enc -aes-256-cbc -pbkdf2 -md md5 -iter 500 -S 0 -iv 0 -in file HINT: salt is 16 characters long

hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

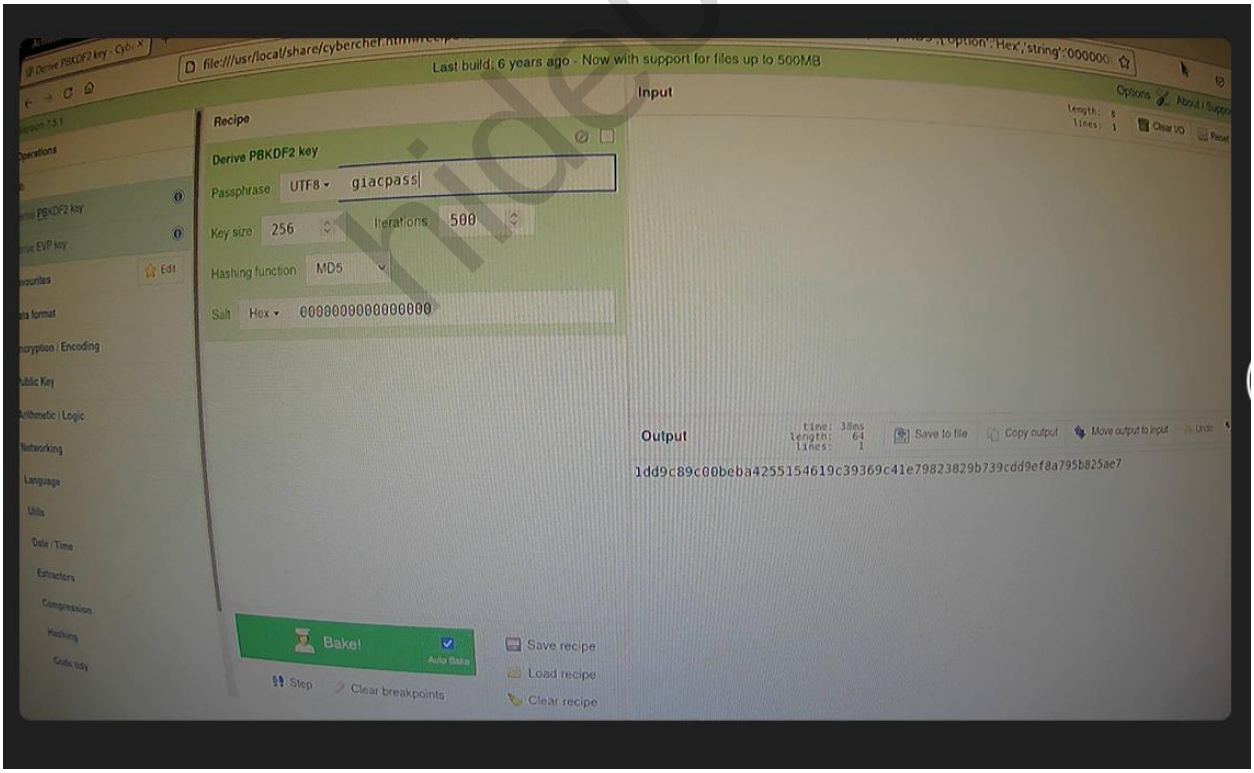
A file was encrypted using the following command and a passkey of "giacpass". Derive the PBKDF2 key in CyberChef. What are the last four characters of the key?

```
openssl enc -aes-256-cbc -pbkdf2 -md md5 -iter 500 -S 0 -iv 0 -in file
```

HINT: Salt is 16 characters long.

View VM

- 5ae7
- 09eb
- 723e
- 37a0
- 43ed
- 214b
- 0ea0
- 73ee
- e11f
- 9b40



hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit

7

Use sqlmap to dump tables from h t tp: // localhost/ index Jogi". plip. The

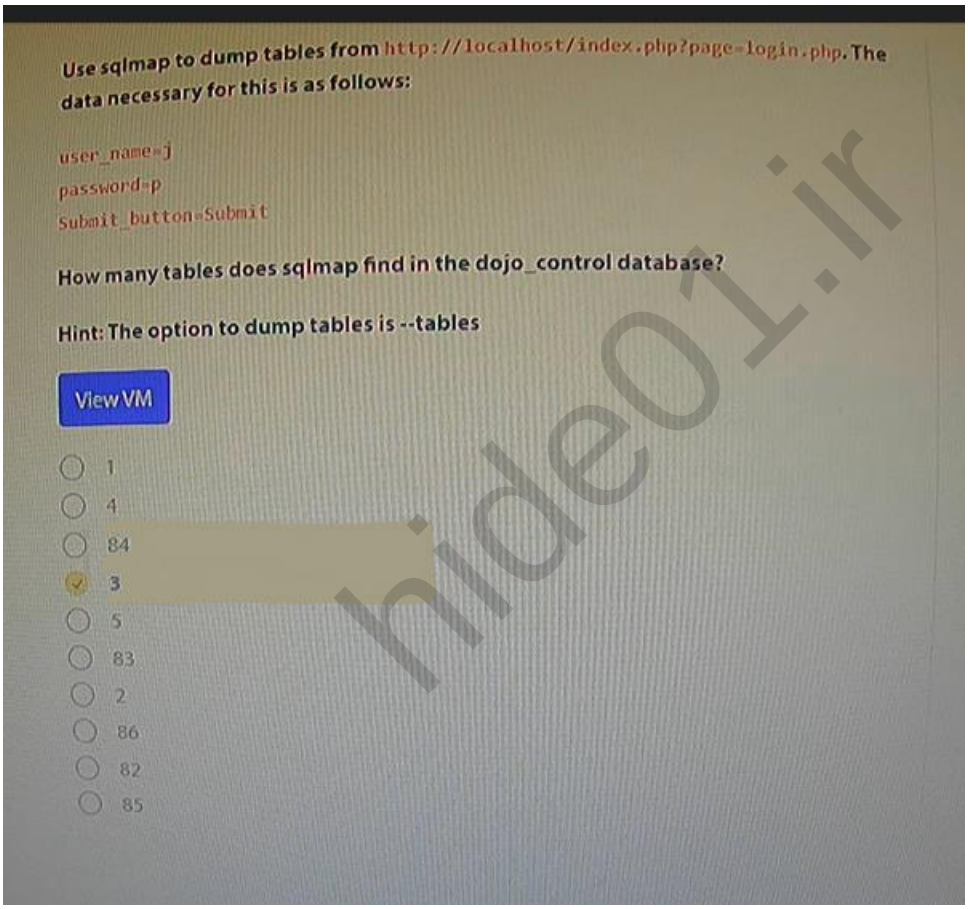
data necessary for this is as follows:

passwordnp

Sutxnit button=Subrnit

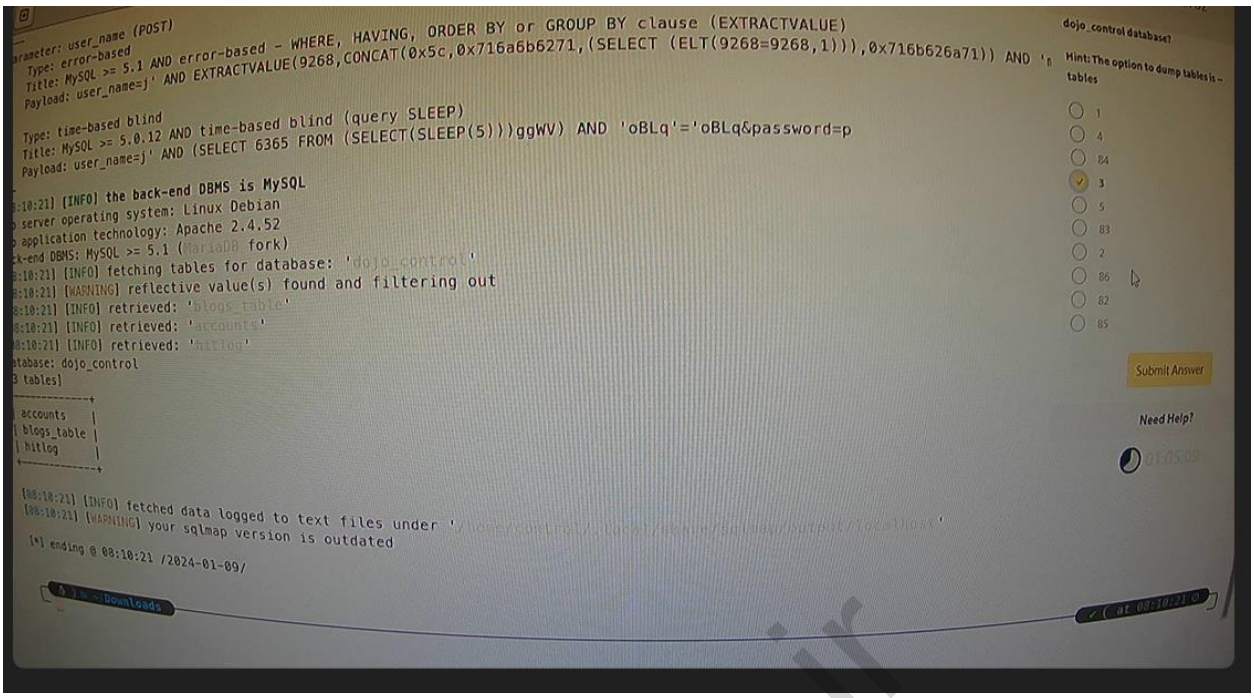
How many tables does sqlmap find in the dojo_control database?

Hint: The option to dump tables is –tables



hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit



hide01.ir

Join us now -> hide01.ir | t.me/RedBlueTM | t.me/Hide01 | t.me/RedBlueHit